COMPLIANCE & SECURITY · PLAYBOOK

Incident Response Playbook Template

For founders and operations leaders who need a clear, ready-to-use first-response sequence for security, privacy, operational and AI incidents.

> **How to use this:** Fill in your decision-makers, severity levels and notification owner now, before an incident happens, and keep this playbook somewhere the whole team can find quickly.

Severity Levels

Define what separates a minor issue from a serious one for your business specifically.

Severity	Example	Who must be involved	Response time target
Low	Single account issue, no data exposure		
Medium	Limited data exposure, contained quickly; AI output error caught before it reached a customer		
High	Customer or personal data exposure, active compromise, ransomware, major outage, or an AI error that reached customers		

Step 1: Contain

- [ ] Identify and stop the immediate exposure (revoke credentials, disable an integration or AI agent, take a system offline).
- [ ] Preserve evidence where possible before making changes (screenshots, logs, timestamps, prompts and outputs).
- [ ] Assign a single incident lead who makes decisions for the duration of the response.
- [ ] Start the clock: record the time the team first had reason to suspect a data breach.

Step 2: Assess

What systems or data are confirmed to be affected? Is personal information involved?

What is still unknown or unconfirmed at this point?

How many customers, accounts or individuals are potentially affected, and in which countries?

© 2026 Rev-IQ. Free to use and adapt.

Is serious harm to any individual likely? Who is making that call, and when will it be made?

Notification Clocks

Check which apply as soon as personal information or a ransom demand is involved. Confirm with an adviser.

Obligation	Trigger	Timeframe
Australia: Notifiable Data Breaches scheme (OAIC)	Eligible data breach likely to cause serious harm	Take all reasonable steps to assess within 30 days of suspecting; notify the OAIC and affected individuals as soon as practicable
Australia: ransomware payment report (ASD)	A ransomware or cyber extortion payment is made by or for a business at or above the A$3 million turnover threshold	Within 72 hours of the payment or of becoming aware of it
New Zealand: Privacy Act 2020 (OPC)	Notifiable privacy breach likely to cause serious harm	As soon as practicable; the Commissioner expects notice within 72 hours
United Kingdom: UK GDPR (ICO)	Personal data breach likely to result in a risk to individuals	Without undue delay and, where feasible, within 72 hours of becoming aware
Customer contracts	As defined in each agreement	Often shorter than the regulator. List your shortest commitment here: ____

Step 3: Communicate

- [ ] Internal stakeholders are notified first, based on severity level.
- [ ] Only confirmed facts are communicated, with no speculation presented as fact.
- [ ] Affected customers are notified if their data or service was impacted, with a clear next-update time.
- [ ] The notification owner has checked every clock in the table above and recorded the decision either way.
- [ ] One person owns all external communication to avoid conflicting messages.

AI Incidents

The same four steps apply. These are the AI-specific events worth naming in advance.

- [ ] Wrong, biased or harmful AI output reached a customer, candidate or the public.
- [ ] Customer, personal or confidential data was entered into an unapproved AI tool or personal account.
- [ ] An AI agent or automation took an action nobody intended (sent, deleted, changed or purchased something).
- [ ] Prompt injection or poisoned content caused an AI feature to leak data or ignore its instructions.
- [ ] An automated decision about an individual is challenged as wrong or unfair.

© 2026 Rev-IQ. Free to use and adapt.

Step 4: Stabilise and Document

What was the root cause, to the best of current knowledge?

What actions were taken, in order, with timestamps?

Which notification decisions were made, by whom, and on what basis?

What will be done differently to prevent recurrence, and who reviews it by when?

Post-Incident Review

- [ ] The timeline is documented while details are still fresh.
- [ ] Root cause and contributing factors are identified without assigning blame.
- [ ] Concrete follow-up actions are assigned to named owners with deadlines.
- [ ] This playbook is updated if the incident revealed a gap in the process itself.

Where This Maps

Framework or obligation	Where this resource lines up
Australian Privacy Act, Part IIIC	Notifiable Data Breaches scheme assessment and notification
Cyber Security Act 2024 (Cth), Part 3	Ransomware and cyber extortion payment reporting
ISO/IEC 27001:2022 Annex A	5.24 to 5.28 incident management planning, assessment, response, learning and evidence; 6.8 event reporting
ASD Essentials for enterprise IT	Visibility and response: incident identification, coordination, response and insights
Australia's Guidance for AI Adoption	Practice 5, test and monitor; practice 6, maintain human control

General guidance, not legal advice. References to standards show where this resource aligns; using it does not make an organisation compliant or certified. Check your specific obligations with a qualified adviser. Regulatory references checked October 2026.

© 2026 Rev-IQ. Free to use and adapt.